

Security Guide



VERSION 1.0

PointMatter
Reporting Solution

Table of Contents

About PointMatter	2
Purpose	2
Scope	2
Deployment Overview	3
PRS System	3
PRS Service Users (ALPHA-1)	5
PRS RELEASE SECURITY PLAN	6
PM Portal OWASP Penetration Test Report	7
OWASP => ZAP Scanning Report	7
Summary of Alerts	7
Alert Detail	7

About PointMatter

PointMatter is web based platform to provide reporting solutions for Compass and BACnet-compliant Building Management Systems (BMS). PointMatter Reporting Solutions (PRS) is designed using the modern frameworks such as DotNet Core and Angular 8 runs on Windows and eventually there are plans to run the platform on Linux and other operating system. This enables Compass operators to report and analyze the performance of their building automation system (BAS). PointMatter current version communicates with the Compass database to sync with key BACnet-compliant objects such as Points, Devices, Alarms, Energy and Trends for reporting purposes.

Purpose

This guide provides administrators with guidance on security and how PRS can be secured, what types of testing is being done and any Certification PRS has gone through.

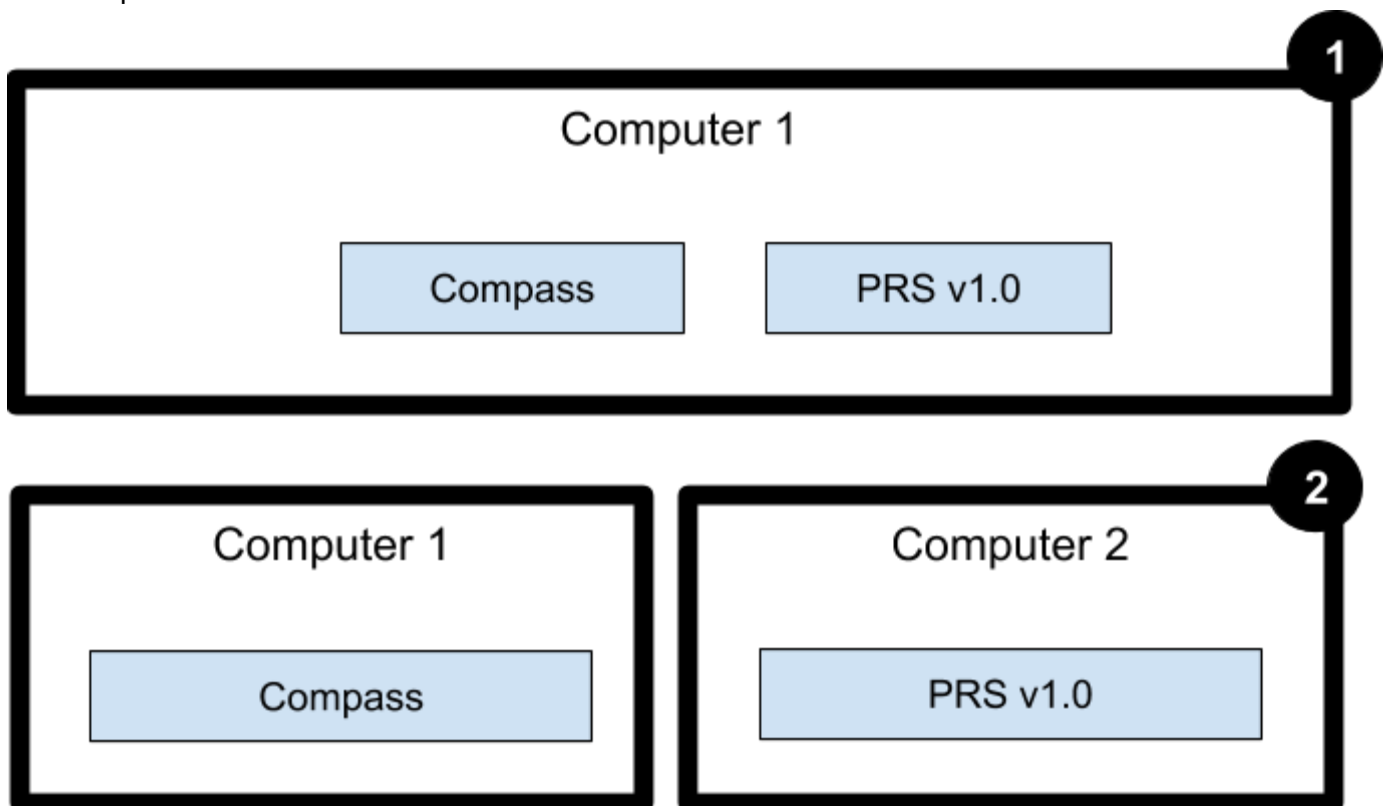
Scope

The focus of the security is Web Application, Database and Binary of Running platform.

Deployment Overview

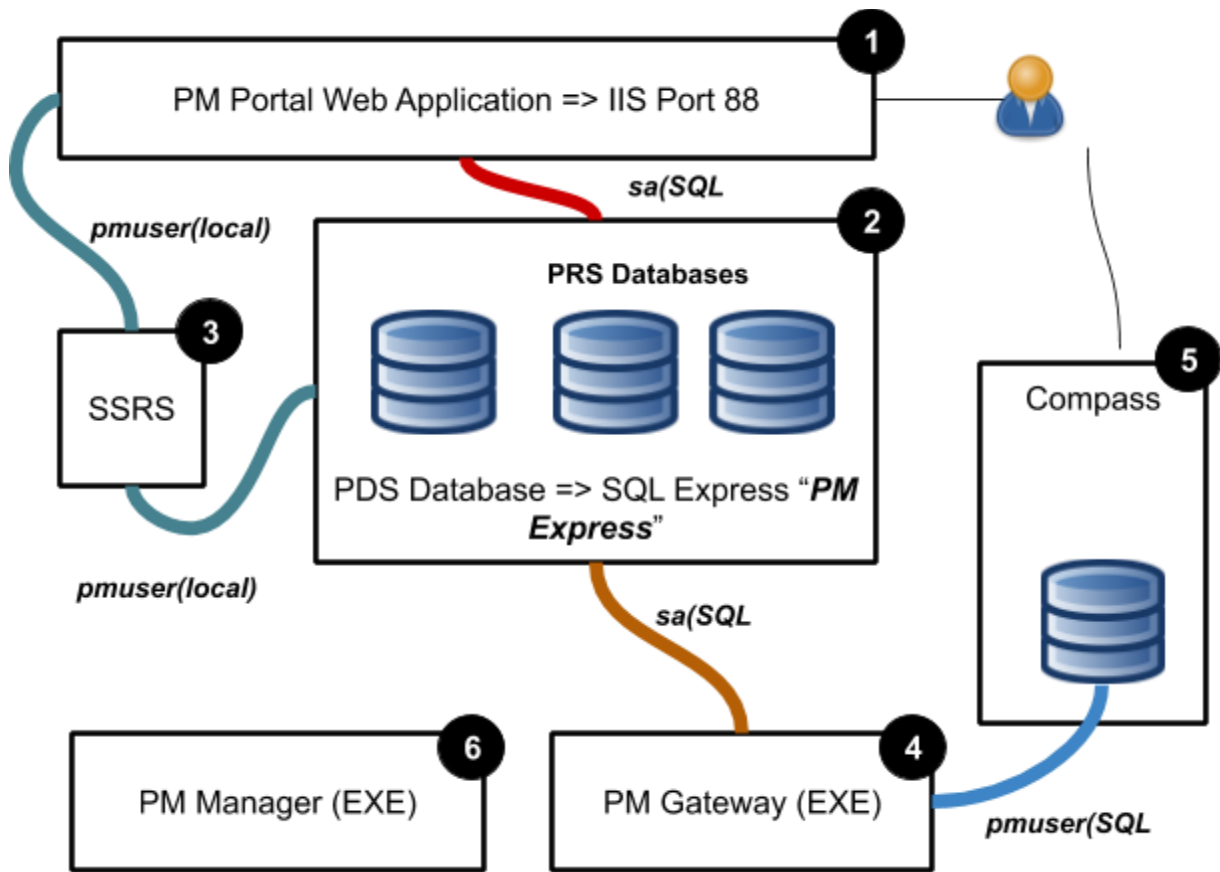
PRS can be installed on the same computer as Compass or on a different computer. PRS connects to the Compass SQL database using a user called “pmuser”. This user is created on the Compass SQL system at installation. It is a read-only account used to send data from the Compass SQL database to the PRS SQL Express database. There are no other interconnections between Compass or the Compass SQL database.

As shown below (1) shows PRS installed on same computer as Compass and (2) shows PRS installed in its own computer or VM.



PRS System

The PRS installation package comes with SQL Express 2017 bundled and uses its own “**PMExpress**” named instance. It runs in its own process controlled and managed by “**sa(SQL)**” user also called with an alias name of **pmadmin**.



No	Component	Purpose	Security Impact
1	PM Portal	A Web Application that runs under its own App Pool in local IIS	Uses pmadmin sa(sql) user to connect to PRS Databases for all reporting data. The Website connection configuration is currently located in web.config and contains the credentials
2	PRS Databases	These are run under PMExpress process and store Reporting Data	There are 2 users who have access to the PRS SQL Express database. The sa(sql) for all connection from ADO.net For SSRS connection, the pmuser(local) is used with SysAdmin permissions to ONLY PRS Databases
3	SSRS	Used for report templates	SSRS connects to the PRS Database using a Datasource configured using pmuser(local) that provides SysAdmin access to PRS Databases ONLY
4	PM	Main Job that runs under	This uses the pmuser(SQL) which is a user with

	Gateway	Windows Scheduler for pulling data from Compass SQL DB	readonly and limited permissions in Compass SQL for accessing SQL data to be copied into PRS Databases
5	Compass	Compass UI connects to Compass SQL to store real time BACnet data	There is no direct connection between PRS system and Compass other than the pmuser(SQL) accessing data from Compass Database
6	PM Manager	Installs PM Portal, Configures SSRS, PRS Databases and Schedules PM Gateway	The PM Manager is run by any person who has access and local admin rights on the machine to install, configure PRS and schedule Gateway jobs

Tighten Security After ALPHA-1 Installation

1. After installation you can go to Windows Account on local machine and change pmuser permissions to User Group from the Admin Group.

PRS Service Users (ALPHA-1)

There are 3 main users that are being created by the PM Manager at the time of installation. These in ALPHA-1 release have a higher level of permissions which will get very limited by the time we release this product in January time frame.

No	User	Alias	Purpose	Security Control
1	pmuser	pmuser(sql)	A Compass SQL User with limited permissions used by PM Gateway to collect data for reporting in PRS	The user is created by PM Manager and can be edited and/or changed using SSMS and connecting to Compass SQL Database
2	pmuser	pmuser(local)	A local Windows user with same name as pmuser is created for accessing PRS Databases	The user is currently a local admin on local machine and can be demoted to standard user and/or deleted using the Windows User Accounts Management Utility
3	sa	pmadmin	The PRS Databases are installed in their own named instances with no conflict with any other database instances. These can be managed using sa(sql) user we call pmadmin (only an alias we use in the documents, actually in the server it is currently sa).	This can be controlled or stopped by using SSMS and connecting to the PMExpress named instance of SQL Server

PRS RELEASE SECURITY PLAN

We have identified the following security tightening areas before the release of ALPHA-1 this is scheduled for end of the year BETA release

No	User	Current	Release Plan (Beta Release)
1	ZAP Penetration Test	There are some medium level risks	We plan to address the key medium level risks before we release
2	pmuser(local)	There is pmuser which we create in local machine with Sysadmin rights on PRS database and Admin on local machine.	This user will be renamed as pmerviceuser and will be a standard local machine user with very limited permissions on PRS databases
3	sa	The SA user has strong password	The sa user will have very strong password and only accessible via local SSMS
4	PM Portal	appsettings.json has a password configuration that is free text	This will be fully encrypted and user will not be sa but pmerviceuser
5	DLL & EXE Signatures	Currently we are not signing any DLLs/EXEs	All packages and DLLs and EXEs will be signed
6	HTTPS	Currently needs manual setup using IIS	Plans to add this feature in PM Manager

PM Portal OWASP Penetration Test Report

We conducted the OWASP ZAP test and have been fixing all high security vulnerabilities. The latest ALPHA-1 Zap Test Results are shared below. We have no HIGH security issues.

OWASP => ZAP Scanning Report

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	1
Low	4
Informational	1

Alert Detail

**Medium
(Medium)**

X-Frame-Options Header Not Set

Description X-Frame-Options header is not included in the HTTP response to protect against 'ClickJacking' attacks.

URL <http://pminstallervm2:86/auth/login>

Method GET

Parameter X-Frame-Options

URL <http://pminstallervm2:86/home/apps>

Method	GET
Parameter	X-Frame-Options
URL	http://pminstallervm2:86/index.html
Method	GET
Parameter	X-Frame-Options
Instances	3
Solution	Most modern Web browsers support the X-Frame-Options HTTP header. Ensure it's set on all web pages returned by your site (if you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. ALLOW-FROM allows specific websites to frame the web page in supported web browsers).
Reference	http://blogs.msdn.com/b/ieinternals/archive/2010/03/30/combating-clickjacking-with-x-frame-options.aspx
CWE Id	16
WASC Id	15
Source ID	3
Low (Medium) X-Content-Type-Options Header Missing	

Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://pminstallervm2:86/11.f1405383c2a9677f9459.js
Method	GET
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/api/ReportManager/runAsync?ReportParams=%7B%22Section%22:3%7D&TenantID=E98F7951-596D-4212-9210-18FD127BE232&Format=pdf&HasChild=true
Method	POST
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/api/TenantManager/CheckTenantExist?tenantName=%5Bobject%20Object%5D&dealerId=
Method	GET
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/index.html
Method	GET
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/api/TenantManager/GetStartEndDates?duration=today

Method	GET
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/api/ReportManager/checkReportName?ReportName=ZAP%20te&TenantId=E98F7951-596D-4212-9210-18FD127BE232
Method	GET
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/api/ReportManager/runAsync?ReportParams=%7B%22RptPath%22:%2260245A1C-C7EA-469F-9511-B10DF5ABA636%22,%22Section%22:1%7D&TenantId=E98F7951-596D-4212-9210-18FD127BE232&Format=HTML5&HasChild=true
Method	POST
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/MaterialIcons-Regular.570eb83859dc23dd0eec.woff2
Method	GET
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/api/AccountManager/logout
Method	GET
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/api/ReportManager/AhdocReporting?TenantId=E98F7951-596D-4212-9210-18FD127BE232
Method	POST
Parameter	X-Content-Type-Options

URL	http://pminstallervm2:86/api/UserManager/GetReportsByUser
Method	POST
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/api/ReportManager/updateReportRunTime?TenantId=E98F7951-596D-4212-9210-18FD127BE232
Method	POST
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/api/ReportManager/checkReportName?ReportName=ZA&TenantId=E98F7951-596D-4212-9210-18FD127BE232
Method	GET
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/api/SearchManager/GetSearchBySid
Method	POST
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/runtime.6024fca6c78beba91def.js
Method	GET
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/api/ReportManager/checkReportName?ReportName=ZAP%20&TenantId=E98F7951-596D-4212-9210-18FD127BE232
Method	GET

Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/api/ReportManager/runAsync?ReportParams=%7B%22RptPath%22:%2260245A1C-C7EA-469F-9511-B10DF5ABA636%22,%22Section%22:1%7D&TenantID=E98F7951-596D-4212-9210-18FD127BE232&Format=HTML5&HasChild=false
Method	POST
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/scripts.c9e67678396b6bf990bc.js
Method	GET
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/api/ReportManager/runAsync?ReportParams=%7B%22RptPath%22:%2260245A1C-C7EA-469F-9511-B10DF5ABA636%22,%22Section%22:%221%22%7D&TenantID=E98F7951-596D-4212-9210-18FD127BE232&Format=HTML5&HasChild=true
Method	POST
Parameter	X-Content-Type-Options
URL	http://pminstallervm2:86/api/ReportManager/checkReportName?ReportName=ZAP%20est%20Report&TenantId=E98F7951-596D-4212-9210-18FD127BE232
Method	GET
Parameter	X-Content-Type-Options
Instances	74

Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Other information	This issue still applies to error type pages (401, 403, 500, etc) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scanner will not alert on client or server error responses.
Reference	http://msdn.microsoft.com/en-us/library/ie/gg622941%28v=vs.85%29.aspx https://www.owasp.org/index.php/List_of_useful_HTTP_headers
CWE Id	16
WASC Id	15
Source ID	3
Low (Medium) Private IP Disclosure	

Description	A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems.
URL	http://pminstallervm2:86/api/ReportManager/runAsync?ReportParams=%7B%22Section%22%3A1%22%22StartDate%22%3A%222019-07-01%2000:00:00%22%22EndDate%22%3A%222019-09-30%2023:59:59%22%7D&TenantID=E98F7951-596D-4212-9210-18FD127BE232&Format=HTML5&HasChild=false
Method	POST
Evidence	192.168.100.110
URL	http://pminstallervm2:86/api/ReportManager/runAsync?ReportParams=%7B%22Section%22%3A3%7D&TenantID=E98F7951-596D-4212-9210-18FD127BE232&Format=HTML5&HasChild=true
Method	POST
Evidence	192.168.100.110
URL	http://pminstallervm2:86/api/ReportManager/runAsync?ReportParams=%7B%22Section%22%3A1%7D&TenantID=E98F7951-596D-4212-9210-18FD127BE232&Format=HTML5&HasChild=false
Method	POST
Evidence	192.168.100.110
URL	http://pminstallervm2:86/api/ReportManager/runAsync?ReportParams=%7B%22RptPath%22%3A%2260245A1C-C7EA-469F-9511-B10DF5ABA636%22%22Section%22%3A1%22%7D&TenantID=E98F7951-596D-4212-9210-18FD

	127BE232&Format=HTML5&HasChild=true
Method	POST
Evidence	192.168.100.110
URL	http://pminstallervm2:86/api/ReportManager/runAsync?ReportParams=%7B%22RptPath%22:%2260245A1C-C7EA-469F-9511-B10DF5ABA636%22,%22Section%22:2%7D&TenantID=E98F7951-596D-4212-9210-18FD127BE232&Format=HTML5&HasChild=false
Method	POST
Evidence	192.168.100.110
URL	http://pminstallervm2:86/api/ReportManager/runAsync?ReportParams=%7B%22Section%22:1%7D&TenantID=E98F7951-596D-4212-9210-18FD127BE232&Format=HTML5&HasChild=true
Method	POST
Evidence	192.168.100.110
URL	http://pminstallervm2:86/api/ReportManager/runAsync?ReportParams=%7B%22RptPath%22:%2260245A1C-C7EA-469F-9511-B10DF5ABA636%22,%22Section%22:2%7D&TenantID=E98F7951-596D-4212-9210-18FD127BE232&Format=HTML5&HasChild=true
Method	POST
Evidence	192.168.100.110
URL	http://pminstallervm2:86/api/ReportManager/runAsync?ReportParams=%7B%22Section%22:2%7D&TenantID=E98F7951-596D-4212-9210-18FD127BE232&Format=HTML5&HasChild=true
Method	POST

Evidence	192.168.100.110
URL	http://pminstallervm2:86/api/ReportManager/runAsync?ReportParams=%7B%22RptPath%22:%2260245A1C-C7EA-469F-9511-B10DF5ABA636%22,%22Section%22:1%7D&TenantID=E98F7951-596D-4212-9210-18FD127BE232&Format=HTML5&HasChild=false
Method	POST
Evidence	192.168.100.110
URL	http://pminstallervm2:86/api/ReportManager/runAsync?ReportParams=%7B%22RptPath%22:%2260245A1C-C7EA-469F-9511-B10DF5ABA636%22,%22Section%22:1%7D&TenantID=E98F7951-596D-4212-9210-18FD127BE232&Format=HTML5&HasChild=true
Method	POST
Evidence	192.168.100.110
Instances	10
Solution	Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP comment instead of HTML/JavaScript comment which can be seen by client browsers.
Other information	192.168.100.110 192.168.100.110
Reference	https://tools.ietf.org/html/rfc1918
CWE Id	200
WASC Id	13

Source ID	3		
		Low (Medium)	Cookie No HttpOnly Flag
Description	A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.		
URL	http://pminstallervm2:86/api/AccountManager/logout		
Method	GET		
Parameter	Identity.External		
Evidence	Set-Cookie: Identity.External		
URL	http://pminstallervm2:86/api/AccountManager/logout		
Method	GET		
Parameter	Identity.TwoFactorUserId		
Evidence	Set-Cookie: Identity.TwoFactorUserId		
URL	http://pminstallervm2:86/api/AccountManager/logout		
Method	GET		
Parameter	.AspNetCore.Identity.Application		
Evidence	Set-Cookie: .AspNetCore.Identity.Application		
Instances	3		

Solution	Ensure that the HttpOnly flag is set for all cookies.	
Reference	http://www.owasp.org/index.php/HttpOnly	
CWE Id	16	
WASC Id	13	
Source ID	3	
	Low (Medium)	Web Browser XSS Protection Not Enabled
Description	Web Browser XSS Protection is not enabled, or is disabled by the configuration of the 'X-XSS-Protection' HTTP response header on the web server	
URL	http://pminstallervm2:86/auth/login	
Method	GET	
Parameter	X-XSS-Protection	
URL	http://pminstallervm2:86/home/apps	
Method	GET	
Parameter	X-XSS-Protection	
URL	http://pminstallervm2:86/index.html	
Method	GET	
Parameter	X-XSS-Protection	
Instances	3	

Solution	Ensure that the web browser's XSS filter is enabled, by setting the X-XSS-Protection HTTP response header to '1'.
Other information	The X-XSS-Protection HTTP response header allows the web server to enable or disable the web browser's XSS protection mechanism. The following values would attempt to enable it: X-XSS-Protection: 1; mode=block X-XSS-Protection: 1; report=http://www.example.com/xss The following values would disable it: X-XSS-Protection: 0 The X-XSS-Protection HTTP response header is currently supported on Internet Explorer, Chrome and Safari (WebKit). Note that this alert is only raised if the response body could potentially contain an XSS payload (with a text-based content type, with a non-zero length).
Reference	https://www.owasp.org/index.php/XSS_(Cross_Site_Scripting)_Prevention_Cheat_Sheet https://www.veracode.com/blog/2014/03/guidelines-for-setting-security-headers/
CWE Id	933
WASC Id	14
Source ID	3
Informational (Low)	Loosely Scoped Cookie

Description	Cookies can be scoped by domain or path. This check is only concerned with domain scope. The domain scope applied to a cookie determines which domains can access it. For example, a cookie can be scoped strictly to a subdomain e.g. www.nottrusted.com, or loosely scoped to a parent domain e.g. nottrusted.com. In the latter case, any subdomain of nottrusted.com can access the cookie. Loosely scoped cookies are common in mega-applications like google.com and live.com. Cookies set from a subdomain like app.foo.bar are transmitted only to that domain by the browser. However, cookies scoped to a parent-level domain may be transmitted to the parent, or any subdomain of the parent.
URL	http://pminstallervm2:86/api/AccountManager/logout
Method	GET
URL	http://pminstallervm2:86/api/AccountManager/login
Method	POST
Instances	2
Solution	Always scope cookies to a FQDN (Fully Qualified Domain Name).
Other information	The origin domain used for comparison was: pminstallervm2 .AspNetCore.Identity.Application= Identity.External= Identity.TwoFactorUserId=

Reference	https://tools.ietf.org/html/rfc6265#section-4.1 https://www.owasp.org/index.php/Testing_for_cookies_attributes_(OTG-SESS-002) http://code.google.com/p/browsersec/wiki/Part2#Same-origin_policy_for_cookies
CWE Id	565
WASC Id	15
Source ID	3